

1. はじめに

1.1 本書の目的

本書は、ミュー株式会社向け製品トレーサビリティ・有効期限管理システム（以下「本システム」）におけるセキュリティ要件を定義し、あわせて現行バージョンにおける **実装状況** を明示するものである。

本書は、貴社における社内セキュリティ審査、および運用開始後の管理策検討の資料として使用できるよう構成している。

1.2 適用範囲

区分	範囲
対象システム	クラウド上に構築された製品トレーサビリティ機能、およびその基盤
対象データ	製造ロット、在庫、出荷履歴、施工会社マスタ、アラート送信履歴、利用者アカウント
対象範囲外	貴社の社内ネットワーク、利用者端末の管理、製造会社・施工会社側のシステム

1.3 実装状況の表記

表記	意味
実装済	現行バージョンで実装され、稼働している
基盤提供	クラウド基盤（Supabase / Vercel）の機能として提供されている
運用対応	技術的措置ではなく、運用ルールによって担保する
今後の課題	現時点では未対応。第12章に対応方針を記載

2. 保護対象と脅威

2.1 情報資産と重要度

資産	内容	機密性	完全性	可用性
在庫・ロット情報	ロット番号、数量、有効期限	中	高	中
出荷履歴	出荷先、出荷日、数量、担当者	高	高	中
施工会社マスタ	会社名、メールアドレス	高	中	中
トレーサビリティQR 発行情報	TraceNo、ロット、有効期限	中	高	中
利用者アカウント	メールアドレス、認証情報	高	高	高
他テナントのデータ	他社の人事・組織データ等	最高	最高	—

本システムは製品情報を扱うため、要配慮個人情報情報は保有しない。ただし、施工会社の担当者メールアドレスおよび利用者アカウント情報は個人情報に該当しうるため、相応の保護を行う。

2.2 想定する脅威

No	脅威	影響	主たる対策
T-01	他テナント利用者による当社データの閲覧・改ざん	取引先情報の漏洩	RLS によるテナント分離（第5章）
T-02	認証を経ないシステムへのアクセス	データの不正閲覧	認証必須化（第4章）
T-03	権限を越えた操作（一般利用者によるマスタ改変等）	データの毀損	役割ベースのメニュー・機能制御（第4章）
T-04	不正な入力値によるデータ破壊	在庫数の不整合	入力検証・データベース制約（第6章）
T-05	通信経路上での盗聴・改ざん	情報漏洩	HTTPS・HSTS（第7章）
T-06	クロスサイトスクリプティング（XSS）	セッション奪取	出力エスケープ・CSP（第7章）
T-07	公開ページ経由の情報漏洩	取引情報の漏洩	公開情報の最小化（第8章）
T-08	公開ページ URL の改ざんによる表示偽装	誤情報の流通	表示内容の非埋め込み設計（第8章）
T-09	同時操作による在庫の不整合	在庫差異・出荷ミス	行ロックとトランザクション（第6章）
T-10	資格情報（APIキー等）の漏洩	全データへの不正アクセス	環境変数管理・サーバー側限定（第10章）
T-11	退職者アカウントの残存	内部不正	アカウント棚卸（第11章）

No	脅威	影響	主たる対策
T-12	端末紛失・共用端末の放置	なりすまし	運用ルール（第11章）

3. セキュリティ設計方針

No	方針	内容
SP-01	多層防御	アプリケーションの条件分岐だけに依存せず、データベース側でもアクセス制御を強制する
SP-02	既定で拒否	認証・テナント情報を取得できない場合は処理を実行しない
SP-03	最小権限	利用者には業務上必要な機能のみを割り当てる。管理者権限のキーはサーバー側でのみ使用する
SP-04	境界での検証	外部から受け取る全ての値を、処理の入口でスキーマ検証する
SP-05	公開情報の最小化	認証不要で公開する情報は、目的達成に必要な最小限に限定する
SP-06	情報を漏らさないエラー	利用者向けエラーには内部構造を含めず、詳細はサーバー側ログにのみ記録する
SP-07	秘密情報をブラウザへ出さない	データベース資格情報・外部 API キーはサーバー側処理でのみ扱う

4. 認証・認可

4.1 認証要件

No	要件	実装状況	実装内容
SEC-A-01	全機能（公開ページを除く）はログインを必須とする	実装済	Middleware が未認証アクセスを検出し、ログイン画面へリダイレクトする
SEC-A-02	認証はクラウド基盤の認証機構を利用する	基盤提供	Supabase Auth によるメールアドレス／パスワード認証
SEC-A-03	セッションは安全に維持・更新される	基盤提供	HTTP Cookie によるセッション管理。リクエストごとにセッションを更新する
SEC-A-04	認証済みでもテナント未特定の場合は処理しない	実装済	全ての読み取り・更新処理の冒頭で利用者とテナントを取得し、未取得なら処理を中断する
SEC-A-05	パスワードは復元不可能な形式で保管される	基盤提供	認証基盤側でハッシュ化して保管
SEC-A-06	パスワードの再設定手段を提供する	基盤提供	パスワードリセット機能

4.2 認可要件

No	要件	実装状況	実装内容
SEC-B-01	役割に応じて利用可能な機能を制限する	実装済	テナント契約（tenant_service）と役割割当（app_role_service）の両方を満たす機能のみメニューに表示する
SEC-B-02	権限のない機能はデータも取得できない	実装済	画面表示制御に加え、各処理で認証・テナント確認とデータベース側のアクセス制御が働く
SEC-B-03	管理者権限の資格情報を一般処理で使用しない	実装済	更新処理では管理者用クライアント（アクセス制御を迂回する接続）を使用しない。使用は公開ページの参照処理1箇所に限定（第8章）

4.3 認可の実装階層

① Middleware	… 未認証アクセスをログイン画面へ誘導
↓	
② メニュー制御	… 契約機能 × 役割割当の両方を満たす機能のみ表示
↓	
③ サーバー処理	… 認証・テナント確認、入力検証、tenant_id 条件の明示付与
↓	
④ データベース	… RLS により他テナントの行を読み書き不可（最終防衛線）

①～③がすべて回避されたとしても、④のデータベース側の制御により他テナントのデータへは到達できない。

5. テナント分離

本システムはマルチテナント SaaS 上で稼働するため、他社データとの分離が最重要のセキュリティ要件である。

5.1 要件と実装

No	要件	実装状況	実装内容
SEC-T-01	全テーブルで行単位のアクセス制御を有効にする	実装済	本システムの全5テーブルで RLS を有効化
SEC-T-02	自テナントの行のみ読み書きできる	実装済	全テーブルにテナント分離ポリシーを設定
SEC-T-03	新規行には自テナントの識別子が自動設定される	実装済	<code>tenant_id</code> の既定値を接続中のテナント識別子とする
SEC-T-04	アプリケーション側でもテナント条件を付与する	実装済	全クエリに <code>tenant_id</code> 条件を明示（RLS との二重防御）
SEC-T-05	データベース関数もテナント分離を維持する	実装済	在庫更新の関数は <code>SECURITY INVOKER</code> （呼び出し利用者の権限で実行）とし、RLS を維持
SEC-T-06	関数内でも参照先のテナントを検証する	実装済	出荷登録関数の内部で、指定された施工会社が自テナントに属するか検証

5.2 テナント分離ポリシー一覧

テーブル	ポリシー名	条件
<code>myou_companies</code>	Tenant Isolation for myou_companies	<code>tenant_id = current_tenant_id()</code>
<code>myou_lots</code>	Tenant Isolation for myou_lots	<code>tenant_id = current_tenant_id()</code>
<code>myou_delivery_logs</code>	Tenant Isolation for myou_delivery_logs	<code>tenant_id = current_tenant_id()</code>
<code>myou_trace_labels</code>	Tenant Isolation for myou_trace_labels	<code>tenant_id = current_tenant_id()</code>
<code>myou_alert_logs</code>	Tenant Isolation for myou_alert_logs	<code>tenant_id = current_tenant_id()</code>

いずれも対象は認証済み利用者（`authenticated`）であり、全操作（`FOR ALL`）に適用される。

5.3 データベース関数における追加検証

在庫を更新するデータベース関数は、利用者が直接呼び出すことも技術的には可能であるため、関数内部でも次の検証を行っている。

関数	検証内容
<code>myou_receive_lot</code>	自テナントのロットのみを検索・更新対象とする
<code>myou_deliver_from_lot</code>	自テナントのロットのみを引当対象とし、かつ指定された施工会社が自テナントに属することを確認する。属さない場合は例外を送出して処理を中止する

6. 入力検証とデータ完全性

6.1 入力検証

No	要件	実装状況	実装内容
SEC-I-01	全ての更新処理でサーバー側の入力検証を行う	実装済	Zod スキーマによる型・書式・範囲の検証
SEC-I-02	画面側の検証のみに依存しない	実装済	更新処理は Server Action として実行され、必ずサーバー側で検証される
SEC-I-03	識別子の形式を検証する	実装済	会社ID・ラベルID・出荷履歴IDは UUID 形式を検証
SEC-I-04	数量の範囲を制限する	実装済	入荷数量は1～100,000、出荷数量は1以上、使用数は0以上かつ出荷数量以下
SEC-I-05	文字列長を制限する	実装済	会社名100文字、メールアドレス255文字、客先注文番号50文字
SEC-I-06	日付の妥当性を検証する	実装済	YYYY-MM-DD 形式かつ実在する日付であることを検証

6.2 インジェクション対策

No	要件	実装状況	実装内容
SEC-I-07	SQL インジェクションを防止する	実装済	クエリビルダおよびパラメータ化されたデータベース関数呼び出しを使用し、文字列連結による SQL 生成を行わない
SEC-I-08	データベース関数の検索パスを固定する	実装済	関数定義で <code>SET search_path = public</code> を指定し、スキーマ差し替えによる攻撃を防止
SEC-I-09	出力時のエスケープを行う	実装済	React による自動エスケープ。危険な HTML 直接挿入は本システムでは使用していない

6.3 データ完全性

No	要件	実装状況	実装内容
SEC-D-01	在庫数量の不整合を防ぐ	実装済	<code>quantity_remaining <= quantity_total</code> 、および各数量の非負をデータベース制約で強制
SEC-D-02	同時操作による更新欠落を防ぐ	実装済	在庫更新は行ロック（FOR UPDATE）を取得したうえで実行
SEC-D-03	複数テーブル更新の部分反映を防ぐ	実装済	在庫減算・出荷履歴登録・QR 発行を単一ランザクションで実行
SEC-D-04	参照整合性を保つ	実装済	出荷履歴・QR 発行は外部キーでロット・施工会社を参照。参照されている施工会社は削除不可

No	要件	実装状況	実装内容
SEC-D-05	状態値の妥当性を保つ	実装済	ロット状態・処理ステータスをデータベースの検査制約で限定
SEC-D-06	番号の一意性を保つ	実装済	ロット番号・TraceNo・出荷先No をテナント内で一意に制約

7. 通信・ブラウザセキュリティ

7.1 通信の保護

No	要件	実装状況	実装内容
SEC-C-01	全通信を暗号化する	実装済	HTTPS による通信。ホスティング基盤で証明書を自動管理
SEC-C-02	HTTPS の使用を強制する	実装済	Strict-Transport-Security: max-age=63072000; includeSubDomains; preload (2年間)
SEC-C-03	混在コンテンツを防ぐ	実装済	CSP の upgrade-insecure-requests (本番環境)

7.2 セキュリティヘッダー

全てのページに以下のヘッダーを付与している。リダイレクトやエラー応答にも適用されるよう、Middleware と設定ファイルの両方で設定している。

ヘッダー	設定値	目的
Strict-Transport-Security	max-age=63072000; includeSubDomains; preload	HTTPS の強制
X-Content-Type-Options	nosniff	内容種別の推測による攻撃の防止
X-Frame-Options	SAMEORIGIN	クリックジャッキングの防止
Referrer-Policy	strict-origin-when-cross-origin	外部サイトへの URL 情報漏洩の防止
Cross-Origin-Opener-Policy	same-origin-allow-popups	別オリジンからのウィンドウ参照の遮断
X-DNS-Prefetch-Control	off	意図しない名前解決の抑止
Permissions-Policy	下記参照	ブラウザ機能の利用制限
Content-Security-Policy	第7.4節参照	外部リソース読み込みの制限

7.3 ブラウザ機能の制限（Permissions-Policy）

機能	設定	理由
カメラ	自サイトのみ許可	QR スキャンに必要
位置情報	自サイトのみ許可	基盤の他機能（勤怠打刻）で使用
マイク	禁止	使用しない
USB / シリアル / Bluetooth / MIDI	禁止	使用しない
加速度・ジャイロ・磁気センサー	禁止	使用しない
画面キャプチャ	禁止	使用しない

7.4 コンテンツセキュリティポリシー（CSP）

ディレクティブ	設定	意図
default-src	'self'	既定は自サイトのみ
script-src	'self' 'unsafe-inline' + 決済サービス	外部オリジンからのスクリプト読み込みを遮断
style-src	'self' 'unsafe-inline' + フォント配信元	—
img-src	'self' data: blob: + データベース基盤	QR・グラフの描画に必要
connect-src	'self' + データベース基盤 + 決済 API	外部への意図しない通信を遮断
frame-ancestors	'self'	他サイトへの埋め込みを禁止
form-action	'self'	フォーム送信先の書き換えを防止
object-src	'none'	プラグインの実行を禁止
base-uri	'self'	基準 URL の乗っ取りを防止

適用モード：既定は `enforce`（違反を実際に遮断する）。想定外の不具合が発生した場合に備え、環境変数により記録のみのモードへ切り替えられる。

既知の制約（重要） `script-src` に `'unsafe-inline'` を含んでいる。これは、採用しているフレームワークがページを実行時にキャッシュ配信する際、リクエストごとに発行する検証値（nonce）が埋め込まれないページが生じ、厳格な設定にすると画面が動作しなくなるためである。この制約により、CSP による **インライン XSS の遮断効果は得られない**。ただし、外部オリジンからのスクリプト読み込み、プラグイン実行、基準 URL の乗っ取り、フォーム送信先の書き換え、他サイトへの埋め込みは実際に遮断される。インライン XSS に対しては、React による自動エスケープと、危険な HTML 直接挿入を行わない実装方針で対応している。

8. 公開ページのセキュリティ

トレーサビリティQR の読み取り先である製品情報公開ページ（ /p/myou/trace/{発行ID} ）は、施工会社・現場作業者が **ログインなし** で 閲覧する設計であり、専用のセキュリティ設計を行っている。

8.1 設計上の課題

課題	内容
認証なしでのデータ参照	通常のアクセス制御は認証済み利用者を前提とするため、そのままでは表示できない
情報漏洩の懸念	公開範囲を誤ると、取引先情報や在庫情報が第三者に閲覧される
表示内容の偽装	QR の内容を書き換えて、虚偽の有効期限等を表示させる恐れがある

8.2 対策

No	要件	実装状況	実装内容
SEC-P-01	公開する情報を最小限に限定する	実装済	ロット番号・施工先No・トレースNo・有効期限の4項目のみ。 出荷先の会社名・担当者名・数量・在庫情報は公開しない
SEC-P-02	表示内容を URL に埋め込まない	実装済	QR には発行ID のみを含め、表示内容はサーバー側でデータベースから取得する。URL を書き換えても表示内容を偽装できない
SEC-P-03	識別子を推測困難にする	実装済	発行ID は UUID （ランダム値）であり、連番ではないため列挙が現実的でない
SEC-P-04	入力値を厳格に検証する	実装済	発行ID が UUID 形式に一致しない場合、データベースへ問い合わせず終了する
SEC-P-05	一覧・検索機能を提供しない	実装済	主キーによる1件取得のみ。全件取得や条件検索の手段を公開しない
SEC-P-06	該当なし時に情報を与えない	実装済	「見つかりません」 ページを返し、存在有無以外の情報を出さない

8.3 管理者用接続の使用について

本ページの参照処理のみ、アクセス制御を迂回する管理者用接続を使用している。これは、認証を前提としない公開ページからは通常の接続でデータを取得できないためである。

統制	内容
使用箇所の限定	公開ページ用の参照処理1箇所限定し、更新処理では一切使用しない
取得列の限定	公開対象の4項目のみを取得する
取得件数の限定	主キーによる1件取得に限定する
実行場所	サーバー側でのみ実行され、資格情報はブラウザへ送信されない
保守時の注意	本処理を改修する際は、取得列・取得条件を必ず見直すこと

9. ログと監査

No	要件	実装状況	実装内容
SEC-L-01	画面アクセスを記録する	実装済	全ての画面表示リクエストを記録（access_logs）
SEC-L-02	出荷操作の実施者を記録する	実装済	出荷履歴に登録担当者名と登録日時を記録
SEC-L-03	通知の送信記録を保持する	実装済	アラート送信履歴に日時・送信先・対象・成否・エラー内容を記録
SEC-L-04	エラーの詳細を記録する	実装済	サーバー側ログにエラーコード・詳細・ヒントを出力
SEC-L-05	ログに秘密情報を含めない	実装済	資格情報・パスワードをログへ出力しない
SEC-L-06	利用者向けエラーに内部情報を含めない	実装済	画面表示は定型メッセージのみとし、内部構造を露出しない
SEC-L-07	マスタ変更の履歴を保持する	今後の課題	施工会社マスタの変更履歴は現在保持していない（第12章）

10. 資格情報・秘密情報の管理

No	要件	実装状況	実装内容
SEC-K-01	秘密情報をソースコードへ埋め込まない	実装済	全て環境変数から取得する
SEC-K-02	管理者権限のキーをブラウザへ露出させない	実装済	サーバー側処理でのみ参照。クライアント側コードから参照しない
SEC-K-03	外部 API の呼び出しをサーバー側で行う	実装済	メール送信等はサーバー側処理で実行
SEC-K-04	環境変数を安全に保管する	基盤提供	ホスティング基盤の環境変数管理機能で暗号化保管
SEC-K-05	漏洩が疑われる場合は速やかに再発行する	運用対応	第11章の運用ルールに定める

10.1 秘密情報の一覧と扱い

変数	内容	公開範囲
NEXT_PUBLIC_SUPABASE_URL	データベース API の接続先	公開可（アクセス制御は別途機能する）
NEXT_PUBLIC_SUPABASE_ANON_KEY	一般利用者用の公開キー	公開可（RLS により権限は制限される）
SUPABASE_SERVICE_ROLE_KEY	管理者権限キー	サーバー側限定・厳重管理
SMTP_USER / SMTP_PASS	メール送信の認証情報	サーバー側限定

SUPABASE_SERVICE_ROLE_KEY はアクセス制御を迂回できる最も重要な資格情報である。漏洩した場合、全テナントのデータへアクセスされる恐れがあるため、取り扱いには特に注意を要する。

11. 運用セキュリティ

技術的措置に加え、以下の運用ルールにより安全性を担保する。実施は貴社の管理担当者にする。

11.1 アカウント管理

No	要件	実施頻度	担当
SEC-O-01	アカウントは利用者ごとに発行し、共用しない	常時	管理担当者
SEC-O-02	権限は業務上必要な最小限とする	発行時・変更時	管理担当者
SEC-O-03	退職・異動時は速やかにアカウントを無効化する	都度	管理担当者
SEC-O-04	アカウントの棚卸を行う	月次	管理担当者
SEC-O-05	パスワードは推測困難なものとし、他システムと使い回さない	常時	全利用者

11.2 端末・利用環境

No	要件	担当
SEC-O-06	共用端末では業務終了後に必ずログアウトする	全利用者
SEC-O-07	ブラウザは最新版を使用する	全利用者
SEC-O-08	端末の紛失・盗難時は速やかに管理担当者へ報告し、該当アカウントを無効化する	全利用者・管理担当者
SEC-O-09	公共の無線 LAN での業務利用を避ける	全利用者

11.3 インシデント対応

段階	対応内容
1. 検知	不審なアクセス・データの異常を発見した場合、直ちに管理担当者へ報告する
2. 初動	該当アカウントを無効化する。データ消失が疑われる場合は 追加の操作を行わない
3. 連絡	サポート窓口へ連絡し、発生日時・事象・影響範囲を共有する
4. 調査	アクセスログ・操作履歴により影響範囲を特定する
5. 復旧	必要に応じてバックアップからリストアする
6. 再発防止	原因に応じて技術的措置・運用ルールを見直す

11.4 バックアップ

項目	内容	区分
データベース	クラウド基盤の自動バックアップ機能に準拠	基盤提供
ソースコード	版管理システムで管理し、任意の時点へ復旧可能	実装済
データベース定義	マイグレーションファイルとして版管理	実装済

12. 残存リスクと今後の対応

現行バージョンで対応していない事項と、その対応方針を明示する。

No	事項	現状のリスク	補完している統制	対応方針
R-01	CSP の <code>script-src</code> に <code>'unsafe-inline'</code> を含む	CSP によるインライン XSS の遮断効果が得られない	React の自動エスケープ、危険な HTML 挿入を行わない実装方針、外部スクリプト読み込みは遮断済み	フレームワークのキャッシュ挙動の改善にあわせ、nonce 方式へ移行する
R-02	施工会社マスタの変更履歴を保持していない	誰がいつ変更したか追跡できない	画面アクセスログにより操作者の特定は可能	監査要件の必要性に応じ、変更履歴テーブルの追加を検討する
R-03	多要素認証を提供していない	認証情報の漏洩時になりすましを受ける	パスワード運用ルール（第11.1節）	基盤側の多要素認証機能の適用を検討する
R-04	TraceNo の採番に競合の可能性がある	同時刻の出荷登録で採番が衝突し、登録が失敗する場合がある	一意制約により重複登録は発生しない。失敗時は再実行で解消する	発生頻度を監視し、必要に応じてデータベース側での採番へ移行する
R-05	有効期限アラートが手動送信である	担当者が確認を怠ると通知漏れが生じる	週次点検の運用ルール（管理者向けマニュアル第8.2節）	自動送信機能の追加を別途ご相談
R-06	IP アドレスによるアクセス制限を行っていない	認証情報があれば社外からもアクセス可能	認証・権限制御・アクセスログ	必要に応じて制限方式をご相談
R-07	データの暗号化は基盤の標準機能に依存	—	基盤側で保管時・転送時の暗号化を実施	追加要件がある場合はご相談

13. セキュリティ要件対応一覧

分類	要件数	実装済	基盤提供	運用対応	今後の課題
認証・認可（第4章）	9	5	4	0	0
テナント分離（第5章）	6	6	0	0	0
入力検証・完全性（第6章）	15	15	0	0	0
通信・ブラウザ（第7章）	3	3	0	0	0
公開ページ（第8章）	6	6	0	0	0
ログ・監査（第9章）	7	6	0	0	1
資格情報管理（第10章）	5	3	1	1	0
運用セキュリティ（第11章）	9	0	0	9	0
合計	60	44	5	10	1

14. 一般的な脅威分類への対応

代表的な Web アプリケーションの脅威分類（OWASP Top 10 の考え方）に対する本システムの対応状況を示す。

脅威分類	対応状況	主な対策
アクセス制御の不備	対応済	認証必須化、役割ベースの機能制御、RLS によるテナント分離（第4・5章）
暗号化の失敗	対応済	全通信の HTTPS 化、HSTS、基盤による保管時暗号化（第7章）
インジェクション	対応済	パラメータ化クエリ、スキーマ検証、出力エスケープ（第6章）
安全でない設計	対応済	多層防御、公開情報の最小化、トランザクションによる完全性確保（第3・6・8章）
セキュリティ設定の不備	対応済	セキュリティヘッダーの全ルート適用、CSP の適用（第7章）
脆弱で古い構成要素	部分対応	最新版のフレームワーク・ライブラリを採用。継続的な更新は保守作業として実施
認証の失敗	部分対応	基盤の認証機構を使用。多要素認証は今後の課題（R-03）
データ完全性の不備	対応済	データベース制約、行ロック、トランザクション（第6章）
ログ・監視の不足	部分対応	アクセスログ・操作記録・送信履歴を保持。マスタ変更履歴は今後の課題（R-02）
サーバーサイドリクエストフォージェリ	該当なし	利用者が指定した URL への外部リクエストを行う機能を持たない

15. 参照

文書番号	文書名	関連箇所
MYOU-RD-001	要件定義書	非機能要件（セキュリティ要件）
MYOU-BD-001	基本設計書	権限・メニュー設計、外部インターフェース設計
MYOU-DD-001	詳細設計書	データベース詳細設計（RLS）、サーバー処理詳細設計、環境変数
MYOU-AM-001	操作マニュアル（管理者向け）	アカウント管理、運用点検、障害時の対応